

Relatorio de Auditoria de Seguranca

Arsenal Open Source - Fabrica Universal

Estagio: Baseline · Data: 2026-08-28

Escopo e metodologia

Linguagens	python, javascript, shell, powershell
Framework	nenhum (CLI/batch, sem servidor HTTP)
Acesso a dados	sqlite3 e better-sqlite3 (SQL cru, parametrizado)
Autenticacao	nenhuma
Frontend	nenhum app; HTML estatico gerado por scripts
Deploy	nenhum arquivo detectado

Cinco categorias auditadas, cada uma mapeada para o equivalente desta stack. Achados verificados por leitura do codigo; varredura textual serviu apenas para levantar candidatos.

Categorias que nao se aplicam

Permissao no navegador: Nao existe frontend com autenticacao. Os HTML gerados sao documentos estaticos sem login, sem papeis e sem backend correspondente.

IDOR: Nao existem rotas HTTP. O inventario de rotas retornou zero handlers reais; o unico input externo e sys.argv local.

Resumo executivo

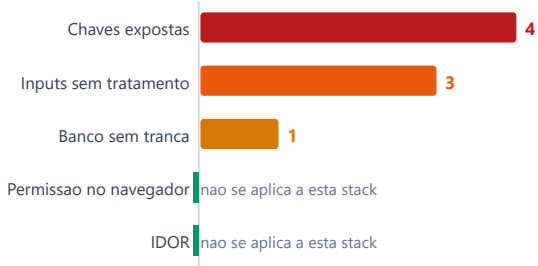
0 CRITICA	2 ALTA	3 MEDIA	1 BAIXA	2 INFORMATIVA
--------------	-----------	------------	------------	------------------

Por severidade

Por categoria



- Alta — 2 (25.0%)
- Media — 3 (37.5%)
- Baixa — 1 (12.5%)
- Informativa — 2 (25.0%)



Pontos fortes

Verificado e correto — delimita a cobertura desta auditoria.

Todas as queries SQL usam statements parametrizados, sem concatenacao de input
`scripts/estado_esteira.py:189 - cursor.execute("SELECT * FROM catalogo_ferramentas WHERE slug = ?", (slug,));` varredura por f-string ou format em contexto SQL retornou zero ocorrencias

Nenhuma chamada de subprocesso usa `shell=True`; todas passam lista de argumentos
`scripts/git_sync.py:33,39,42,48,56; scripts/auditar_todas_camadas.py:42; scripts/compilar_ecossistema_tripartite.py:2409,3014`

Ausencia total de `eval`, `new Function`, `os.system` e desserializacao insegura
Varredura dos padroes `eval/exec/pickle.loads/yaml.load` em 1048 arquivos: zero ocorrencias em codigo de producao

O `.env` com credenciais reais nunca foi versionado
`git ls-files --error-unmatch .env` retorna erro; `git log --all -- .env` retorna vazio; `.gitignore:19` cobre o arquivo

Parsing de HTML feito com BeautifulSoup, nao por manipulacao de string
`scripts/aplicar_padrao_diamante_49.py:78-97 - soup = BeautifulSoup(content, "html.parser")` com insercao por nó

Compilacoes externas validam codigo de saida em vez de ignorar falha
`scripts/compilar_ecossistema_tripartite.py:2409 - subprocess.run(..., check=True)`

Achados

Severidade	Arquivo:linha	Descricao
Alta	<code>.env:3, 8, 13, 18</code>	Credenciais de producao em texto plano no <code>.env</code> local
Alta	<code>output/05-auditorias-vps/</code>	Segredos de exemplo versionados em manuais gerados do Fluxo 5
Media	<code>scripts/</code>	Ausencia de validacao de startup para variaveis criticas
Media	<code>.git/hooks/</code>	Ausencia de hook que bloqueie commit de segredo
Media	<code>scripts/gerar-index-organizacao.py:66, 71, 72</code>	Interpolacao sem escape de dado de terceiro no gerador do portal
Baixa	<code>scripts/git_sync.py:71</code>	Mensagem de commit vinda de argv sem validacao
Informativa	<code>scripts/aplicar_padrao_diamante_49.py:53</code>	innerHTML com template string no JavaScript gerado
Informativa	<code>scripts/estado_esteira.py:36, 184</code>	Ausencia de coluna de proprietario no esquema da esteira

Banco sem tranca

Informativa `scripts/estado_esteira.py:36, 184`

Ausencia de coluna de proprietario no esquema da esteira

```
CREATE TABLE IF NOT EXISTS esteira_listas_horizontais ( id INTEGER PRIMARY KEY AUTOINCREMENT, slug TEXT NOT NULL UNIQUE, ... )
```

Por que e explorável: Nao e vulnerabilidade: o banco e local, monousuario, e nenhuma das oito tabelas e exposta por rede. Registrado como divida arquitetural porque nenhuma tabela possui coluna de dono ou tenant; converter a esteira em servico multiusuario sem adicionar isolamento faria toda query listar dados de todos.

Impacto: Nenhum na arquitetura atual.

Condicoes: Materializa-se apenas se o projeto expuser a esteira como servico multiusuario.

Correcao: Se houver essa evolucao, adicionar coluna de tenant e filtro obrigatorio nas funcoes de leitura.

Chaves expostas

Alta

.env:3, 8, 13, 18

Credenciais de producao em texto plano no .env local

```
GITHUB_TOKEN="ghp_****"  
PORTAINER_PASSWORD="****"  
VPS_PASSWORD="****"  
MAUTIC_PASSWORD="****"
```

Por que e explorável: PAT do GitHub, senha do painel Portainer, senha root da VPS e senha do Mautic ficam legíveis por qualquer processo ou pessoa com acesso ao sistema de arquivos da estacao. Verificado que o arquivo NAO esta versionado (git ls-files e git log --all -- .env retornam vazio), portanto nao ha vazamento via repositório.

Impacto: Comprometimento da estacao expoe repositório GitHub, orquestrador de containers e acesso root ao servidor 167.86.69.79.

Condicoes: Requer acesso local ao sistema de arquivos. Nao explorável remotamente pelo repositório.

Correcao: Migrar para gerenciador de segredos ou variaveis de ambiente do SO. Criar .env.example com placeholders. Adicionar validacao de startup que recuse valores default.

Alta

output/05-auditorias-vps/

Segredos de exemplo versionados em manuais gerados do Fluxo 5

```
APP_SECRET=****  
DB_PASSWORD=****  
POSTGRES_PASSWORD: ****  
Chave Secreta (JWT): ****
```

Por que e explorável: 38 linhas com atribuicao de segredo aparecem no historico git, todas originadas de manuais de instalacao gerados. Sao valores literais de baixa entropia apresentados como configuracao pronta, nao como placeholder. O publico-alvo declarado na R21 e explicitamente nao-tecnico, o que torna o copiar-e-colar o comportamento esperado.

Impacto: Instalacoes derivadas desses manuais entram em producao com segredo conhecido e publicado, permitindo forja de JWT e acesso ao banco.

Condicoes: Materializa-se quando o leitor segue o manual sem substituir os valores.

Correcao: Alterar os compiladores para emitir placeholders (\${APP_SECRET}) e incluir instrucao de geracao com openssl rand -hex 32. Regenerar os manuais afetados.

Media scripts/

Ausencia de validacao de startup para variaveis criticas

Nenhum script verifica se GITHUB_TOKEN, PORTAINER_PASSWORD ou VPS_PASSWORD foram definidos ou continuam com valor de exemplo.

Por que e explorável: Sem gate de inicializacao, executar um fluxo com .env ausente ou preenchido com valores de exemplo nao falha de imediato; a falha aparece adiante, em estado parcial, ou o script opera com credencial de exemplo.

Impacto: Configuracao incorreta passa despercebida e pode gerar execucao parcial contra ambiente errado.

Condicoes: Nenhuma. Reproduzivel rodando qualquer fluxo sem .env.

Correcao: Criar validar_env.py que recusa variavel ausente ou igual a valor de exemplo, e chama-lo no inicio dos fluxos que consomem credencial.

Media .git/hooks/

Ausencia de hook que bloqueie commit de segredo

CLAUDE.md R15 declara que o hook pre-commit bloqueia deteccoes de segredo, mas 38 linhas de segredo entraram no historico.

Por que e explorável: A regra R15 e documental. O que efetivamente entrou no historico prova que nao ha barreira mecanica funcionando para este padrao.

Impacto: Proximo segredo commitado passa sem barreira.

Condicoes: Nenhuma.

Correcao: Implementar hook de pre-commit que varre o diff staged por padroes de segredo e aborta o commit.

Inputs sem tratamento

Media

scripts/gerar-index-organizacao.py:66, 71, 72

Interpolacao sem escape de dado de terceiro no gerador do portal

```
card = f"""
<div class="repo-card" data-name="{name.lower()}" data-desc="{desc.lower()}" ...>
  <h3 class="repo-title">{name}</h3>
  <p class="repo-desc">{desc}</p>
```

Por que e explorável: name e desc vem de gh repo list --json (linha 23-26), ou seja, do campo descricao de repositórios do GitHub, controlável por quem tem escrita naquele repositório. A interpolacao ocorre em f-string sem html.escape, tanto em contexto de atributo (linha 66, onde uma aspa fecha o atributo) quanto em contexto de elemento (linhas 71-72). O projeto não possui nenhuma lib de sanitizacao.

Impacto: Descricao contendo "><script> injeta script no portal gerado, executado por quem abrir a pagina.

Condicoes: Requer um repositório com descricao hostil na organizacao auditada. Explorável por qualquer colaborador com escrita em repositório listado.

Correcao: Aplicar html.escape() em name, desc, url e parent_slug antes da interpolacao, com quote=True para o contexto de atributo.

Baixa

scripts/git_sync.py:71

Mensagem de commit vinda de argv sem validacao

```
msg = sys.argv[1] if len(sys.argv) > 1 else "feat(esteira): atualizacao automatica de
artefatos open source"
```

Por que e explorável: O valor vai para subprocess.run(["git", "commit", "-m", msg]) na linha 48. A lista de argumentos impede injecao de shell, portanto não ha execucao arbitraria. Resta que uma mensagem iniciada com hifen e interpretada pelo git como flag.

Impacto: Limitado: comportamento inesperado do git commit. Não ha execucao de comando arbitrario.

Condicoes: Requer controle sobre o argumento de linha de comando, que ja pressupoe acesso local.

Correcao: Rejeitar mensagem iniciada por hifen e limitar o conjunto de caracteres aceitos.

Informativa

scripts/aplicar_padrao_diamante_49.py:53

innerHTML com template string no JavaScript gerado

```
counter.innerHTML = `Exibindo <b>${count}</b> de <b>${entries.length}</b> fichas`;
```

Por que e explorável: Não e explorável no estado atual: count e entries.length são inteiros derivados do DOM, sem origem externa. Registrado porque o padrao vira XSS na primeira refatoracao que introduza dado de usuario, e o mesmo padrao se repete em scripts/gerar-index-organizacao.py:196.

Impacto: Nenhum hoje.

Condicoes: Depende de refatoracao futura que traga dado externo para a interpolacao.

Correcao: Usar textContent para o texto e elementos separados para a formatacao.

Issues para o GitHub

Cada bloco abaixo e uma issue completa, pronta para copiar.

```
--- ISSUE 1 ---
## [Seguranca] Credenciais de producao em texto plano no .env local

**Labels:** `security`, `alta`
**Categoria:** Chaves expostas

### Problema

PAT do GitHub, senha do painel Portainer, senha root da VPS e senha do Mautic ficam legiveis por qualquer processo ou pessoa com acesso ao sistema de arquivos da estacao. Verificado que o arquivo NAO esta versionado (git ls-files e git log --all -- .env retornam vazio), portanto nao ha vazamento via repositorio.

### Evidencia

`.env:3, 8, 13, 18`

```
GITHUB_TOKEN="ghp_****"
PORTAINER_PASSWORD="****"
VPS_PASSWORD="****"
MAUTIC_PASSWORD="****"
```

### Impacto

Comprometimento da estacao expoe repositorio GitHub, orquestrador de containers e acesso root ao servidor 167.86.69.79.

**Condicoes:** Requer acesso local ao sistema de arquivos. Nao explorável remotamente pelo repositorio.

### Correcao sugerida

Migrar para gerenciador de segredos ou variaveis de ambiente do SO. Criar .env.example com placeholders. Adicionar validacao de startup que recuse valores default.

### Criterios de aceite

- [ ] Correcao aplicada em `.env`
- [ ] Teste automatizado que falha antes e passa depois
- [ ] Nova varredura nao reporta este achado
- [ ] Credencial rotacionada no provedor (o valor antigo esta comprometido)
--- FIM ISSUE 1 ---
```


--- ISSUE 2 ---

[Seguranca] Segredos de exemplo versionados em manuais gerados do Fluxo 5

****Labels:**** `security`, `alta`

****Categoria:**** Chaves expostas

Problema

38 linhas com atribuicao de segredo aparecem no historico git, todas originadas de manuais de instalacao gerados. Sao valores literais de baixa entropia apresentados como configuracao pronta, nao como placeholder. O publico-alvo declarado na R21 e explicitamente nao-tecnico, o que torna o copiar-e-colar o comportamento esperado.

Evidencia

`output/05-auditorias-vps/:-`

```

APP\_SECRET=\*\*\*\*

DB\_PASSWORD=\*\*\*\*

POSTGRES\_PASSWORD: \*\*\*\*

Chave Secreta (JWT): \*\*\*\*

```

Impacto

Instalacoes derivadas desses manuais entram em producao com segredo conhecido e publicado, permitindo forja de JWT e acesso ao banco.

****Condicoes:**** Materializa-se quando o leitor segue o manual sem substituir os valores.

Correcao sugerida

Alterar os compiladores para emitir placeholders (\${APP_SECRET}) e incluir instrucao de geracao com openssl rand -hex 32. Regenerar os manuais afetados.

Criterios de aceite

- [] Correcao aplicada em `output/05-auditorias-vps/`
- [] Teste automatizado que falha antes e passa depois
- [] Nova varredura nao reporta este achado
- [] Credencial rotacionada no provedor (o valor antigo esta comprometido)

--- FIM ISSUE 2 ---

```
--- ISSUE 3 ---  
## [Seguranca] Ausencia de validacao de startup para variaveis criticas  
  
**Labels:** `security`, `media`  
**Categoria:** Chaves expostas  
  
### Problema  
  
Sem gate de inicializacao, executar um fluxo com .env ausente ou preenchido com valores de exemplo  
nao falha de imediato; a falha aparece adiante, em estado parcial, ou o script opera com  
credencial de exemplo.  
  
### Evidencia  
  
`scripts/:-`  
  
```  
Nenhum script verifica se GITHUB_TOKEN, PORTAINER_PASSWORD ou VPS_PASSWORD foram definidos ou
continuam com valor de exemplo.
```  
  
### Impacto  
  
Configuracao incorreta passa despercebida e pode gerar execucao parcial contra ambiente errado.  
  
**Condicoes:** Nenhuma. Reproduzivel rodando qualquer fluxo sem .env.  
  
### Correcao sugerida  
  
Criar validar_env.py que recusa variavel ausente ou igual a valor de exemplo, e chama-lo no inicio  
dos fluxos que consomem credencial.  
  
### Criterios de aceite  
  
- [ ] Correcao aplicada em `scripts/`  
- [ ] Teste automatizado que falha antes e passa depois  
- [ ] Nova varredura nao reporta este achado  
- [ ] Credencial rotacionada no provedor (o valor antigo esta comprometido)  
--- FIM ISSUE 3 ---
```

```
--- ISSUE 4 ---  
## [Seguranca] Ausencia de hook que bloqueie commit de segredo  
  
**Labels:** `security`, `media`  
**Categoria:** Chaves expostas  
  
### Problema  
  
A regra R15 e documental. O que efetivamente entrou no historico prova que nao ha barreira  
mecanica funcionando para este padrao.  
  
### Evidencia  
  
`.git/hooks/:-`  
  
` ` `   
CLAUDE.md R15 declara que o hook pre-commit bloqueia deteccoes de segredo, mas 38 linhas de  
segredo entraram no historico.  
` ` `   
  
### Impacto  
  
Proximo segredo commitado passa sem barreira.  
  
**Condicoes:** Nenhuma.  
  
### Correcao sugerida  
  
Implementar hook de pre-commit que varre o diff staged por padroes de segredo e aborta o commit.  
  
### Criterios de aceite  
  
- [ ] Correcao aplicada em `.git/hooks/`  
- [ ] Teste automatizado que falha antes e passa depois  
- [ ] Nova varredura nao reporta este achado  
- [ ] Credencial rotacionada no provedor (o valor antigo esta comprometido)  
--- FIM ISSUE 4 ---
```

```
--- ISSUE 5 ---  
## [Seguranca] Interpolacao sem escape de dado de terceiro no gerador do portal  
  
**Labels:** `security`, `media`  
**Categoria:** Inputs sem tratamento  
  
### Problema  
  
name e desc vem de gh repo list --json (linha 23-26), ou seja, do campo descricao de repositorios  
do GitHub, controlavel por quem tem escrita naquele repositorio. A interpolacao ocorre em f-string  
sem html.escape, tanto em contexto de atributo (linha 66, onde uma aspa fecha o atributo) quanto  
em contexto de elemento (linhas 71-72). O projeto nao possui nenhuma lib de sanitizacao.  
  
### Evidencia  
  
`scripts/gerar-index-organizacao.py:66, 71, 72`  
  
...  
card = f"""  
<div class="repo-card" data-name="{name.lower()}" data-desc="{desc.lower()}" ...>  
  <h3 class="repo-title">{name}</h3>  
  <p class="repo-desc">{desc}</p>  
...  
  
### Impacto  
  
Descricao contendo "><script> injeta script no portal gerado, executado por quem abrir a pagina.  
  
**Condicoes:** Requer um repositorio com descricao hostil na organizacao auditada. Explorável por  
qualquer colaborador com escrita em repositorio listado.  
  
### Correcao sugerida  
  
Aplicar html.escape() em name, desc, url e parent_slug antes da interpolacao, com quote=True para  
o contexto de atributo.  
  
### Criterios de aceite  
  
- [ ] Correcao aplicada em `scripts/gerar-index-organizacao.py`  
- [ ] Teste automatizado que falha antes e passa depois  
- [ ] Nova varredura nao reporta este achado  
  
--- FIM ISSUE 5 ---
```

--- ISSUE 6 ---

[Seguranca] Mensagem de commit vinda de argv sem validacao

****Labels:**** `security`, `baixa`

****Categoria:**** Inputs sem tratamento

Problema

O valor vai para subprocess.run(["git","commit","-m", msg]) na linha 48. A lista de argumentos impede injecao de shell, portanto nao ha execucao arbitraria. Resta que uma mensagem iniciada com hifen e interpretada pelo git como flag.

Evidencia

`scripts/git\_sync.py:71`

```

```
msg = sys.argv[1] if len(sys.argv) > 1 else "feat(esteira): atualizacao automatica de artefatos open source"
```

```

Impacto

Limitado: comportamento inesperado do git commit. Nao ha execucao de comando arbitrario.

****Condicoes:**** Requer controle sobre o argumento de linha de comando, que ja pressupoe acesso local.

Correcao sugerida

Rejeitar mensagem iniciada por hifen e limitar o conjunto de caracteres aceitos.

Criterios de aceite

- [] Correcao aplicada em `scripts/git\_sync.py`
- [] Teste automatizado que falha antes e passa depois
- [] Nova varredura nao reporta este achado

--- FIM ISSUE 6 ---